

Authentication Models

Information Security



Course Outline

Course Name: Information Security

Credit Hours: 3(3-0)

Prerequisites: Data Communication and Computer Networks

Course Outline:

Basic notions of confidentiality, integrity, availability; authentication models; protection models; security kernels; Encryption, Hashing and Digital Signatures; audit; intrusion detection and response; database security, hostbased and network-based security issues operational security issues; physical security issues; personnel security; policy formation and enforcement; access controls; information flow; legal and social issues; identification and authentication in local and distributed systems; classification and trust modeling; risk assessment

Reference Materials:

1. *Computer Security: Art and Science*, Matthew Bishop
2. *Cryptography and Network Security* by William Stalling 6th Edition, 2012
3. *Principles of Information Security* 3rd E by Michael E. Whitman and Herbert J. Mattord

Authentication Models

- Authentication is the *process of verifying the identity of a user, device, or system.*
- In information security, authentication is *used to ensure that only authorized entities are allowed access to protected resources or information.*

Authentication Models cont...

Means of Authentication

- There are four general means of authenticating a user's identity, which can be used alone or in combination:
- **1- Something the individual knows:** Examples include a *password*, a *personal identification number* (PIN), or *answers to a prearranged set of questions*.

Authentication Models cont...

Means of Authentication

- 2- Something the individual possesses: Examples include *cryptographic keys, electronic keycards, smart cards, and physical keys.*
- This type of authenticator is referred to as a *token*.
- 3- Something the individual is (static biometrics): Examples include recognition by *fingerprint, retina, and face.*

Authentication Models cont...

Means of Authentication

- 4- Something the individual does (dynamic biometrics): Examples include recognition by *voice pattern*, *handwriting characteristics*, and *typing rhythm*.

Authentication Models cont...

- There are several authentication models in information security, including:
 1. **Single-factor authentication**
 2. **Two-factor authentication (2FA)**
 3. **Multi-factor authentication (MFA)**

Authentication Models cont...

- 4. Risk-based authentication**
- 5. Federated authentication**
- 6. Adaptive authentication**
- 7. Continuous authentication**

Authentication Models cont...

Single-factor authentication

- Single-factor authentication (SFA) is a method of verifying a user's identity by *requiring only one piece of information* or *credential*, typically a password, in order to grant access to a system or resource.
- SFA is the most basic form of authentication and is still widely used, particularly in consumer applications.

Authentication Models cont...

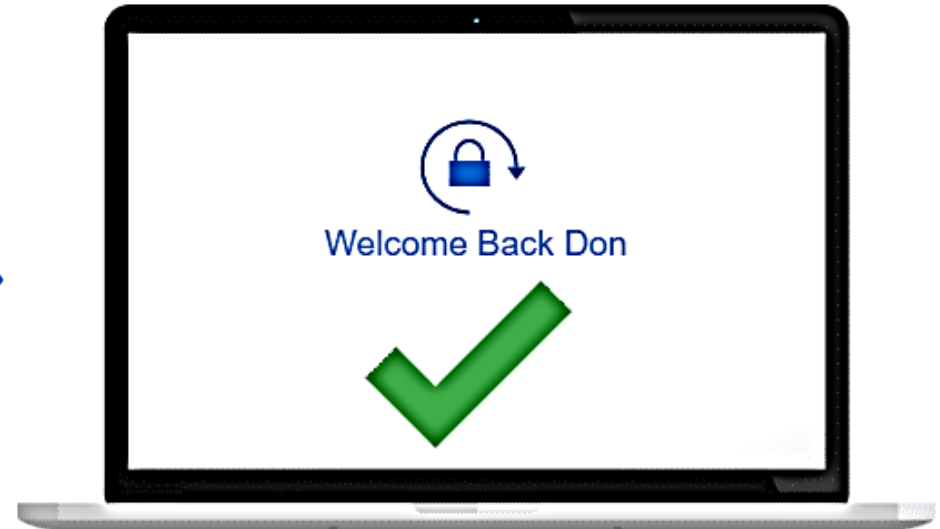
Single-factor authentication

Example of Single Factor Authentication

User Enters User Name and Password



User is Authenticated



Authentication Models cont...

Single-factor authentication

- However, it is generally considered to be *less secure* than multi-factor authentication (MFA), which requires additional verification methods beyond just a password.
- The weaknesses of SFA lie in the fact that passwords can be easily guessed or stolen, leaving systems vulnerable to unauthorized access.

Authentication Models cont...

Single-factor authentication

- This is why many organizations have moved towards implementing **MFA**, which adds an additional layer of security by requiring users to provide a second form of authentication, such as a fingerprint or a security token, in addition to their password.

Authentication Models cont...

Two-factor authentication

- Two-factor authentication (2FA) is a security process in which a ***user provides two different authentication factors*** to verify their identity.
- This adds an ***extra layer of security to prevent unauthorized access*** to sensitive data or accounts.
- The two factors can be any combination of the following:

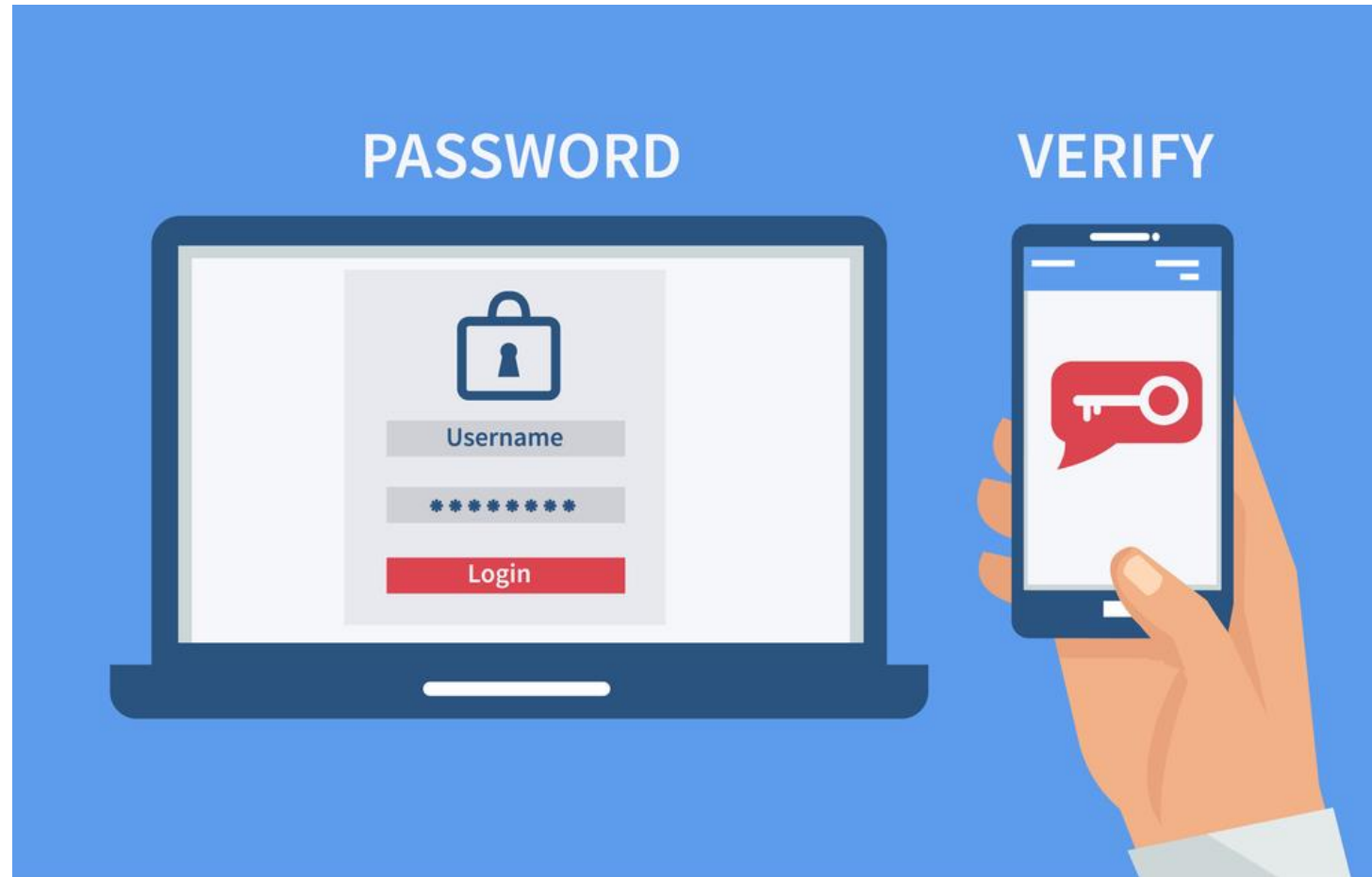
Authentication Models cont...

Two-factor authentication

- Something the user knows (knowledge factor), such as a *password* or *PIN*.
- Something the user has (possession factor), such as a *smartphone*, *hardware token*, or *smart card*.
- Something the user is (inherence factor), such as a *fingerprint*, *voice recognition*, or *facial recognition*.

Authentication Models cont...

Two-factor authentication



Authentication Models cont...

Two-factor authentication

- To authenticate using 2FA, the user is required to provide two of the above factors.
- For example, when logging into an account, the user enters their password (something they know) and receives a unique code on their smartphone (something they have) that they must also enter to gain access.

Authentication Models cont...

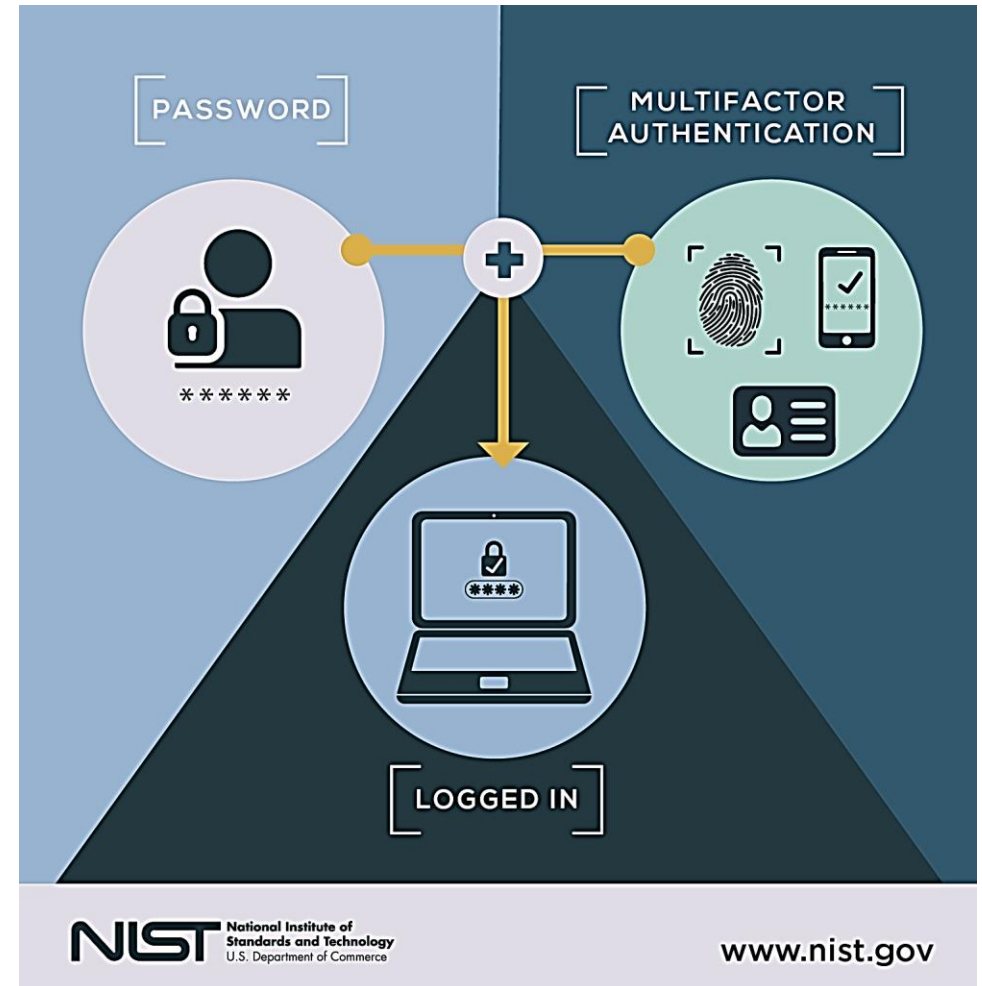
Two-factor authentication

- This makes it much more difficult for an attacker to gain unauthorized access to the account, as they would need to obtain both factors rather than just one (e.g., by stealing a password or a device).

Authentication Models cont...

Multi-factor authentication

- Multi-factor authentication (MFA) is a security mechanism that requires the user to provide ***two or more forms of identification*** before being granted access to a system, application, or device.



Authentication Models cont...

Multi-factor authentication

- The three main categories of authentication factors used in MFA are:
- Something you know: knowledge factor
- Something you have: possession factor
- Something you are: inherence factor

Authentication Models cont...

Multi-factor authentication

- Using multiple factors of authentication reduces the risk of unauthorized access, as an attacker would need to possess more than just one factor of authentication to gain access to the system.

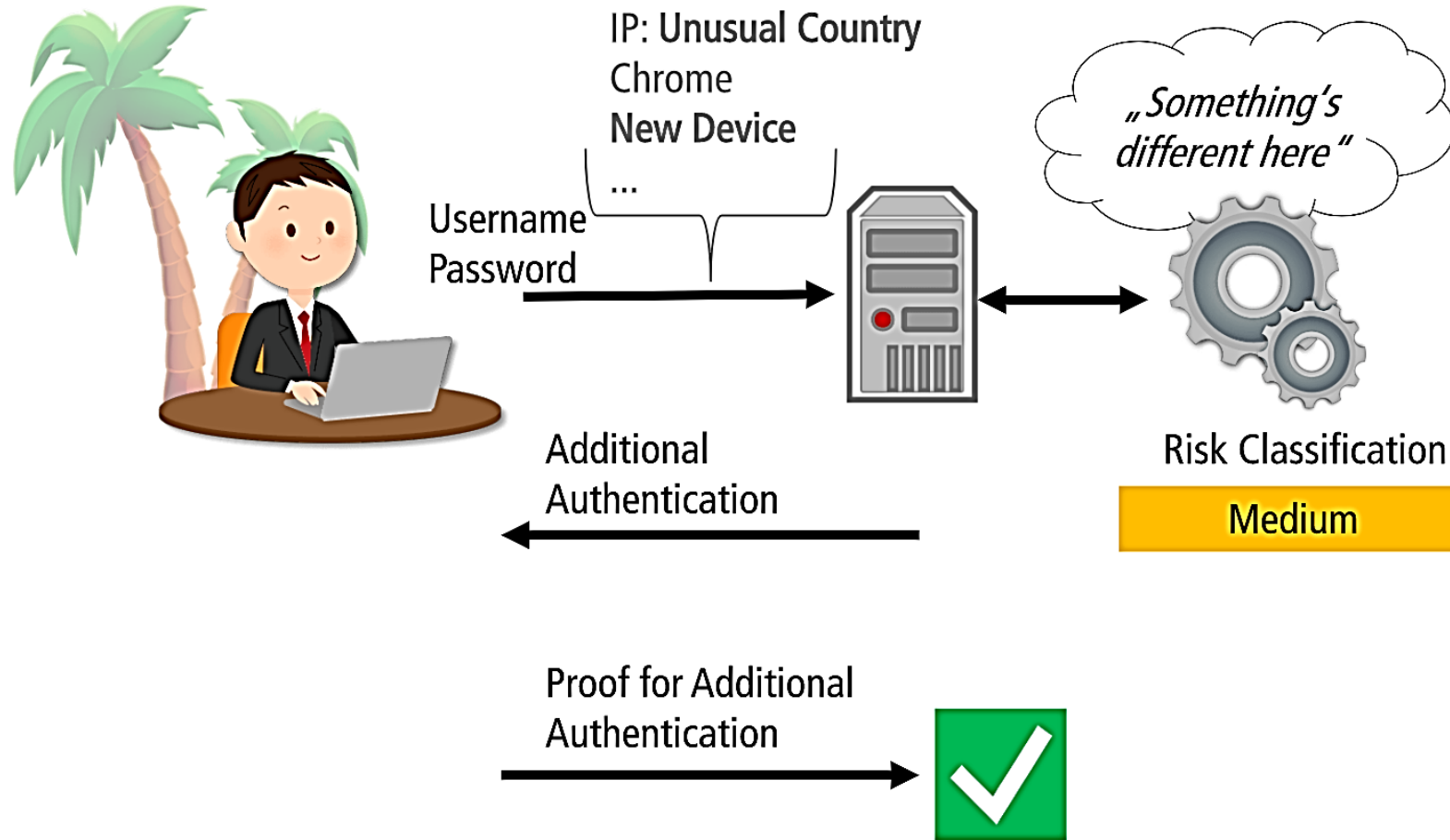
Authentication Models cont...

Risk-based authentication

- Risk-based authentication is an *adaptive security measure* that is *used to evaluate the risk level* associated with a particular login attempt or transaction.
- It takes into account a variety of factors such as the user's location, device information, IP address, and other contextual data to determine the level of risk associated with the attempted access.

Authentication Models cont...

Risk-based authentication



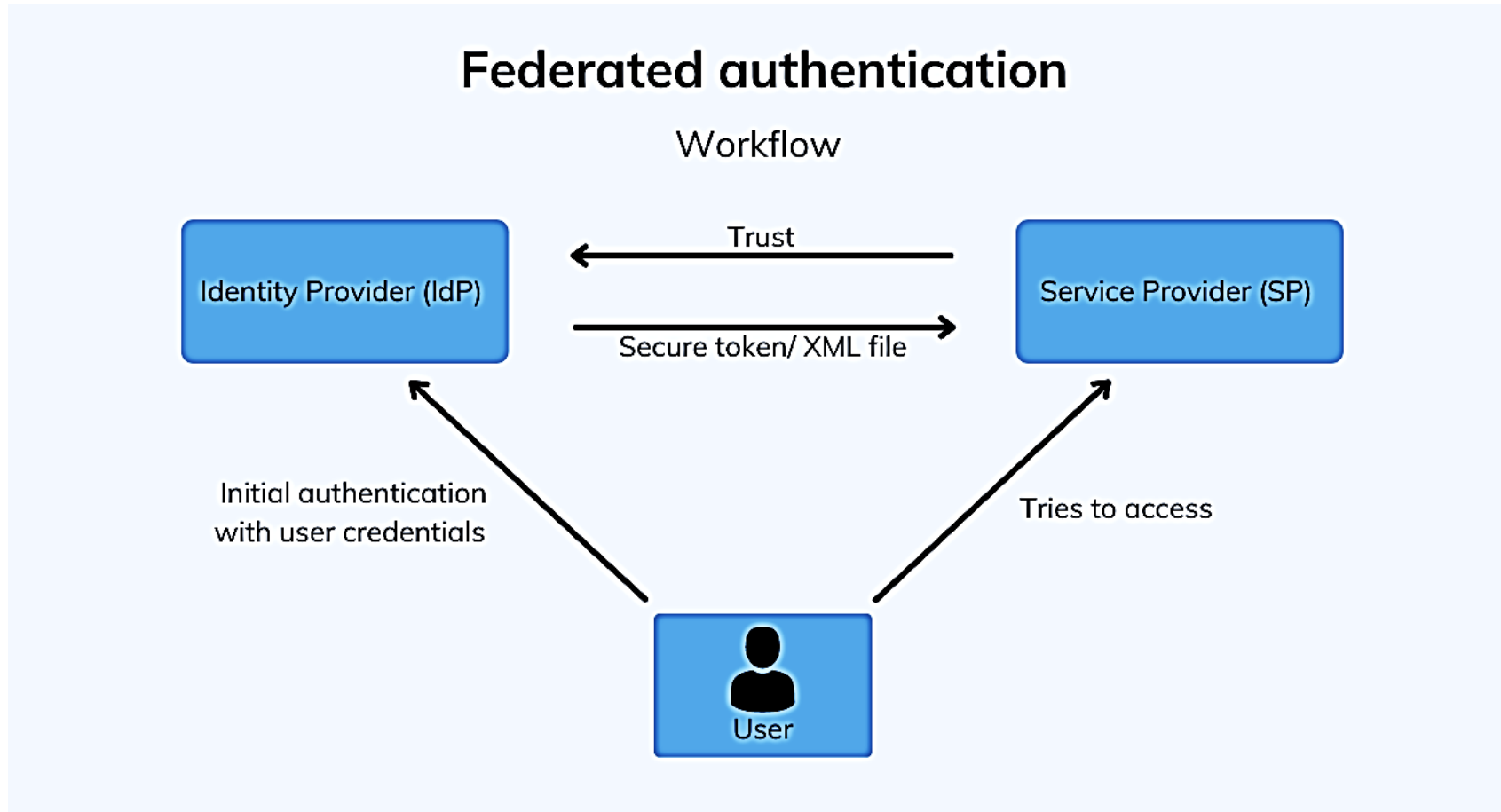
Authentication Models cont...

Risk-based authentication

- Based on the risk score, different authentication methods can be used.
- For example, *if the risk score is high*, the *user may be required to provide additional authentication factors* such as *biometric verification* or a *one-time passcode*.
- Risk-based authentication helps to improve the security of the authentication process by allowing organizations to tailor the authentication method based on the risk level associated with the login attempt.

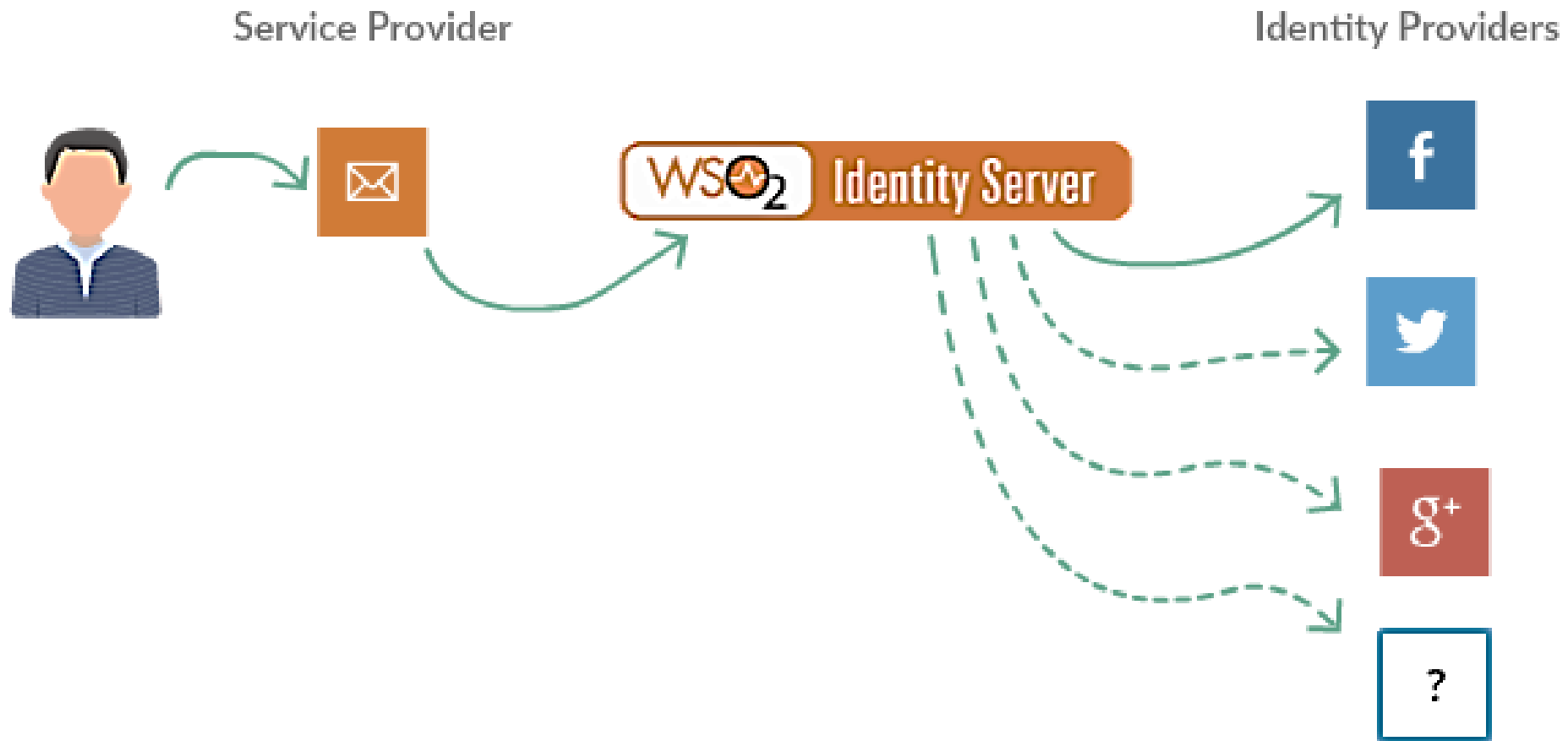
Authentication Models cont...

Federated authentication



Authentication Models cont...

Federated authentication



Authentication Models cont...

Federated authentication

- Federated authentication is a mechanism that allows users to ***access multiple applications and services*** using a single set of credentials.
- In this authentication model, the user's identity is first verified by an identity provider (IdP) and then ***shared with other service providers (SPs) to grant access*** to their respective services.

Authentication Models cont...

Federated authentication

- Federated authentication *allows for better user experience* and *convenience* as users *do not have to remember multiple sets of credentials* for different services.
- It also *provides a centralized control* for Identity and Access Management (IAM) and *reduces the administrative overhead* of managing user accounts across multiple applications and services.

Authentication Models cont...

Federated authentication

- However, there are also *security concerns* related to *federated authentication*.
- If the *identity provider is compromised*, it can *result in unauthorized access* to multiple services.
- Additionally, federated authentication introduces a *single point of failure*, making it important to implement appropriate security measures to protect the identity provider and the communication channels between the identity provider and service providers.

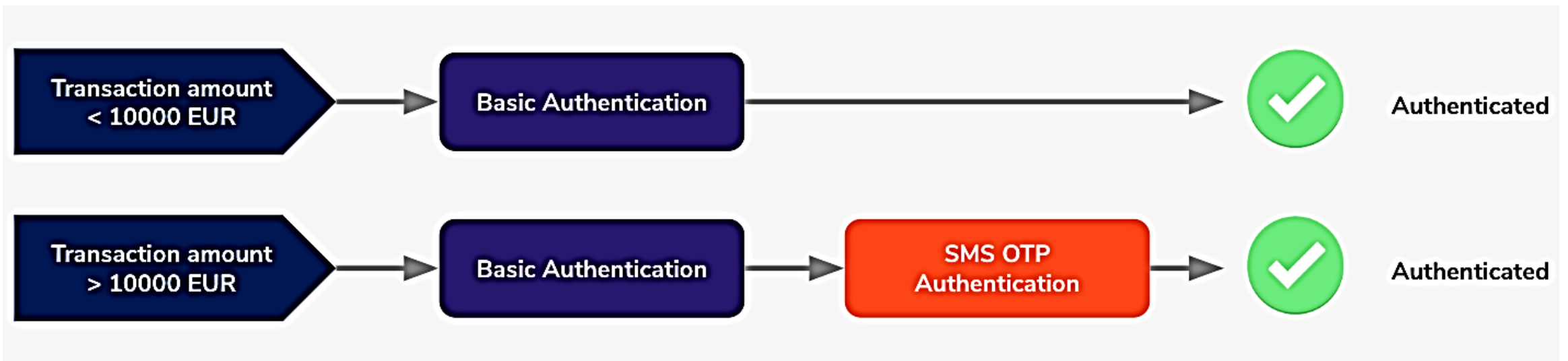
Authentication Models cont...

Adaptive authentication

- Adaptive authentication is a type of authentication that uses contextual information and risk assessment to determine the appropriate level of authentication needed for a specific user or transaction.
- This approach to authentication can help improve security by dynamically adjusting the authentication requirements based on the perceived risk level of the user or transaction.

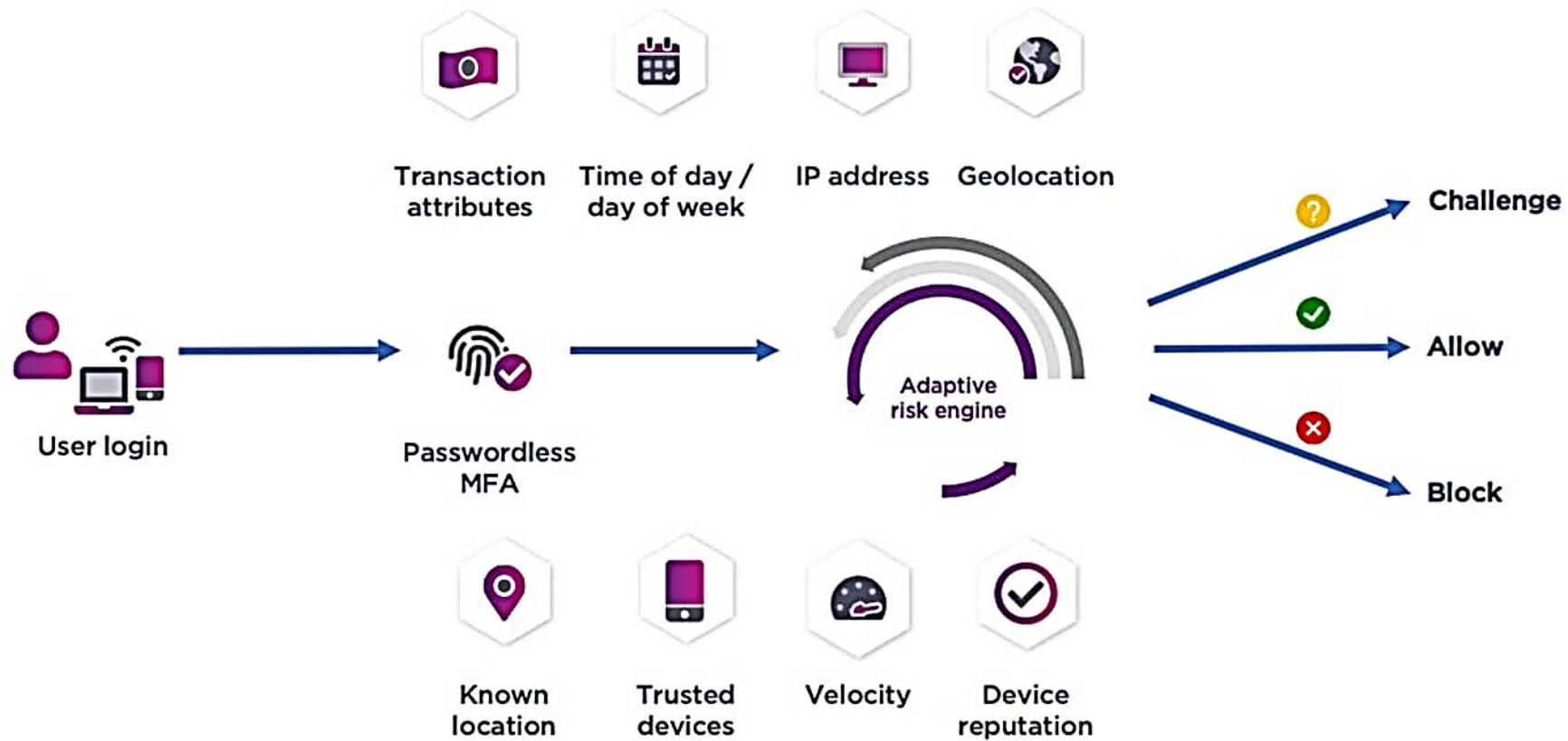
Authentication Models cont...

Adaptive authentication



Authentication Models cont...

Adaptive authentication



Authentication Models cont...

Adaptive authentication

- Adaptive authentication typically involves collecting and analyzing various types of data to assess risk, such as *user behavior patterns*, *device* and *location information*, and other *contextual factors*.
- Based on this analysis, the system can then require additional authentication factors or restrict access if a *high-risk scenario is detected*, or allow seamless access for low-risk scenarios.

Authentication Models cont...

Adaptive authentication

- Adaptive authentication can help organizations balance security and usability by minimizing the need for unnecessary authentication challenges, while still providing robust protection against unauthorized access and fraud.

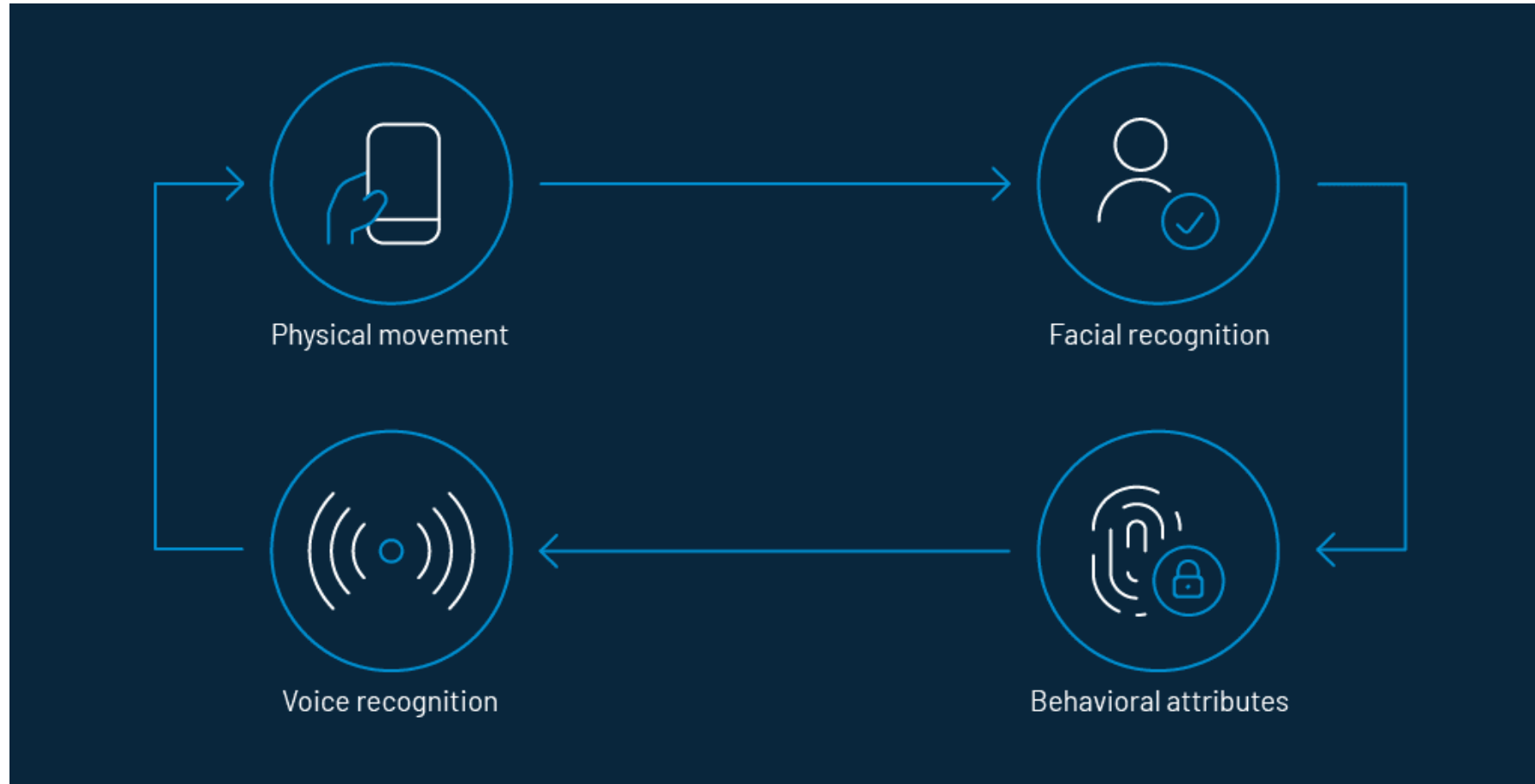
Authentication Models cont...

Continuous authentication

- Continuous authentication is a security approach that aims to provide *ongoing authentication* of users based on their *behavior patterns*, *activities*, and other *contextual factors*.
- This contrasts with traditional authentication methods, such as passwords, that only provide a one-time authentication at the initial login.

Authentication Models cont...

Continuous authentication



Authentication Models cont...

Continuous authentication

Continuous authentication
vs Multi-factor authentication



Multi-factor authentication

- Verifies a user's identity only once during login
- Can serve as a solid user verification solution on its own
- Is a common requirement of IT compliance regulations



Continuous authentication

- Verifies a user's identity multiple times during the user session
- Supplements and significantly enhances MFA
- Is not a mandatory security measure

Authentication Models cont...

Continuous authentication

- Continuous authentication systems monitor user behavior *in real-time*, and they *analyze patterns of activity* to determine if there are any anomalies that could indicate fraudulent behavior.
- These systems may use a variety of data sources to build a profile of a user's normal behavior, such as the device they are using, their location, the time of day, their typical activities, and more.-

Authentication Models cont...

Continuous authentication

- Continuous authentication can be useful in *detecting and preventing insider threats*, where *legitimate users may attempt to steal data* or *compromise systems*.
- It can also provide enhanced security for remote workers, who may be accessing corporate resources from a variety of devices and locations.

Authentication Models cont...

Continuous authentication

- There are several technologies that can be used to implement continuous authentication, including machine *learning algorithms*, *behavioral biometrics*, and risk-based authentication models.
- The goal of these technologies is to provide a more seamless and secure authentication experience, while also reducing the risk of data breaches and other security incidents.